DevSecOps: integrar seguridad en el ciclo de vida del software

- **DevSecOps**
  - Arquitectura y diseño seguro
    - Diseño incorrecto: fallas difíciles de corregir
    - No hacer más de lo autorizado
    - Software de seguridad ≠ seguridad del software
    - Transformar requisitos en decisiones concretas
    - Arquitectura resiliente y segura
    - Guiada por decisiones y mitigaciones
  - Propósito y enfoque
    - Integra desarrollo, operaciones, calidad y seguridad
    - Seguridad desde el inicio, no al final
    - Subconjunto de DevOps orientado a ciberseguridad
    - Responsabilidad compartida
    - Equipos integrados y colaboración continua
  - Manifiesto DevSecOps
    - Pensar como atacante
    - APIs y automatización accesibles
    - Monitoreo 24/7
    - TDD para detectar fallas temprano
    - Colaboración abierta
    - Cumplimiento continuo
    - Ser proactivo
    - Pruebas ofensivas
    - Entrenamiento
    - Inteligencia de amenazas compartida
    - Métricas orientadas al negocio
    - Principios se convierten en prácticas → SDL
    - Compromiso organizacional
  - Análisis de riesgos y aplicación en DevOps
    - Priorizar riesgos críticos según impacto
    - Ciclo continuo por etapas
      - Operar
      - Responder
      - Integrar
      - Desplegar
      - Planificar
      - Desarrollar
      - Monitorear
      - Probar
    - Guía decisiones y mitigaciones → Arquitectura y diseño seguro
    - Beneficios
      - Identificar activos, amenazas, vulnerabilidades, impacto y mitigaciones
      - Mejor recuperación
      - Despliegues robustos
      - Mayor disponibilidad
      - Mayor velocidad
      - Menos fallos
  - SDL — Security Development Life Cycle
    - Creado por Microsoft
    - Requisitos seguros→ Compromiso→Conocimiento → Modelado de amenazas → Diseño seguro → Revisión de código → Test de seguridad → Security release → Respuesta de seguridad
    - Aplicaciones conectadas a internet incrementan riesgos y amenazas
    - Seguridad integrada en cada fase
    - Modelo económico del atacante
      $M_\beta + P_\beta > O^l_p + O^l_m \cdot P_a \cdot P^l$
      - $M_\beta$ = beneficio monetario para el atacante; $P_\beta$ = esfuerzo psicológico para el atacante
      - $O^l_p$ = costo de cometer el delito; $O^l_m$ = costo económico de la condena: pérdidas futuras y costos legales
      - $P_a$ = probabilidad de ser detenido y arrestado; $P^l$ = probabilidad de ser condenado